UNIVERSITY OF CENTRAL PUNJAB

Faculty of Information Technology

Cyber Security

Week 4 — Cyber Threats, Service Attacks & Reconnaissance

Common Cyber Threats • DoS / DDoS & Service Attacks
Footprinting & Reconnaissance • Tools & Safe Practice

Instructor: Hafiz Usama Ishtiaq

BSCS • 3 Credit Hours • Fall 2026

QUICK RECAP

Where We Are So Far

Week 1	Cybersecurity basics, the CIA Triad, and key terminology.
Week 2	Threats, threat actors, internal vs external, and common attacks.
Week 3	Vulnerabilities, the OWASP Top 10, and CVE / CVSS / NVD.
This week	Common threats in depth, service (DoS) attacks, and how attackers gather info first.

WEEK 4 ROADMAP

What We Will Cover This Week

1

Common Cyber Threats

A closer look at the attacks organizations face every day

2

Service Attacks (DoS / DDoS)

Attacks that knock systems and websites offline

3

Footprinting & Reconnaissance

How attackers gather information before striking

4

Tools & Safe Practice

Recon and defense tools, plus legal labs to practise in

Common Cyber Threats — The Landscape

These are the attacks students and organizations meet most often. We'll define each one:

Malware

Viruses, ransomware, spyware and more

Phishing

Fake messages that steal data or logins

Password attacks

Guessing, cracking or reusing credentials

DoS / DDoS

Flooding a service so it stops working

Man-in-the-middle

Secretly intercepting communication

Insider threats

Harm from people who already have access

COMMON THREATS

A Closer Look (1 of 2)

Phishing	**Fake emails/texts that trick you into giving data or clicking.** **Example:** "Your parcel is held — pay a fee here" leading to a fake page.
Ransomware	**Malware that locks your files and demands payment.** **Example:** A hospital's records encrypted until a ransom is paid.
Password attack	**Guessing or cracking passwords to break into accounts.** **Example:** Trying millions of combinations until the login works.
Man-in-the-middle	**Secretly sitting between two parties to read/change data.** **Example:** Intercepting login data over open cafe Wi-Fi.

A Closer Look (2 of 2)

SQL injection	**Inserting database commands through a web input.** **Example:** Typing code into a login box to read the whole database.
Drive-by download	**Malware installed just by visiting a hacked website.** **Example:** A compromised site that infects visitors automatically.
Supply-chain attack	**Attacking a trusted vendor to reach their customers.** **Example:** Malware hidden inside a legitimate software update.
Insider threat	**Harm caused by someone who already has access.** **Example:** An employee leaking confidential data to a competitor.

FOCUS

Spotting a Phishing Message

Phishing is the most common way attacks begin. Learn to spot the warning signs:

Urgency / fear

"Act now or your account is closed!"

Odd sender address

support@paypa1-secure.com (note the '1')

Generic greeting

"Dear Customer" instead of your name

Suspicious links

A link that doesn't match the real website

Spelling mistakes

Poor grammar and awkward wording

Unexpected attachments

A file you didn't ask for — don't open it

PART 2

Service Attacks

How attackers make websites and systems stop working (Denial of Service).

What is a Denial-of-Service (DoS) Attack?

A DoS attack floods a system with so much fake traffic or requests that real users can no longer use it.

Simple analogy: imagine 10,000 fake customers crowding into a shop's doorway. Real customers can't get in — the shop is effectively "closed."

Goal

Availability — knock the service offline (the 'A' in CIA)

How

Overload the server, bandwidth, or an application

Result

Slow service, crashes, and lost business

KNOW THE DIFFERENCE

DoS vs DDoS

DoS

Denial of Service

- Comes from ONE computer/source
- Easier to block (one address)
- Smaller in scale

DDoS

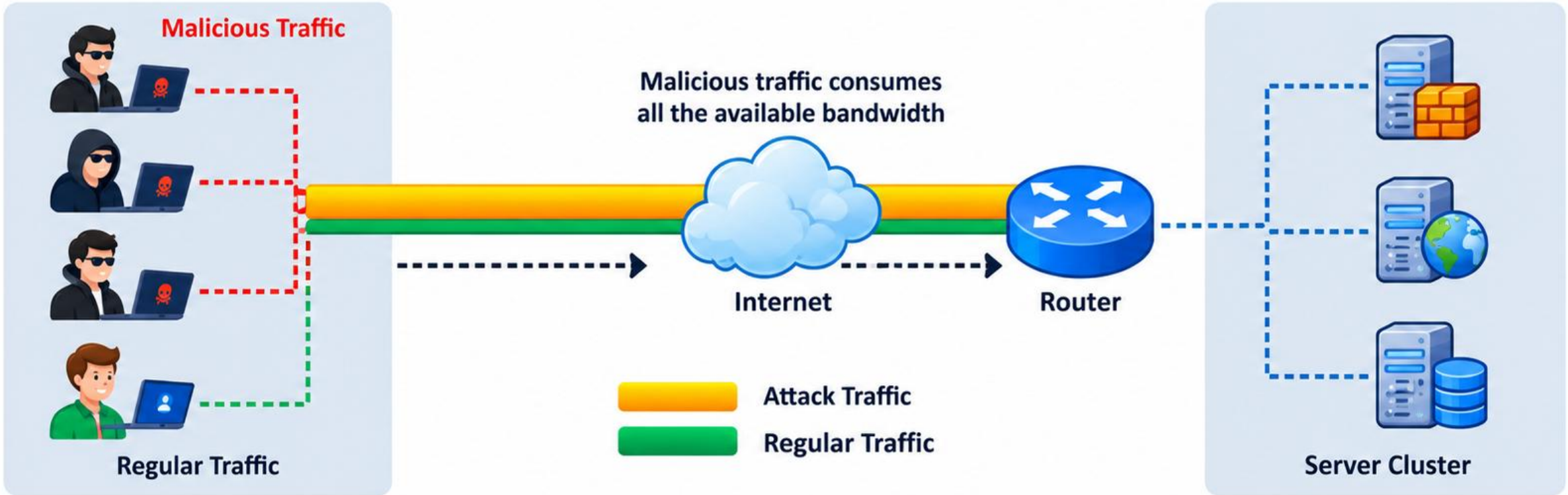
Distributed Denial of Service

- Comes from THOUSANDS of devices (a botnet)
- Very hard to block (many addresses)
- Massive in scale — can take down big sites

What is a Denial-of-Service Attack?

- Denial-of-Service (DoS) is an attack on a computer or network that **reduces, restricts, or prevents** accessibility of system resources to its legitimate users.
- In a DoS attack, attackers flood the victim system with **non-legitimate service requests or traffic** to overload its resources.





Denial-of-Service

DoS/DDoS Concepts

What is a Distributed Denial-of-Service Attack?

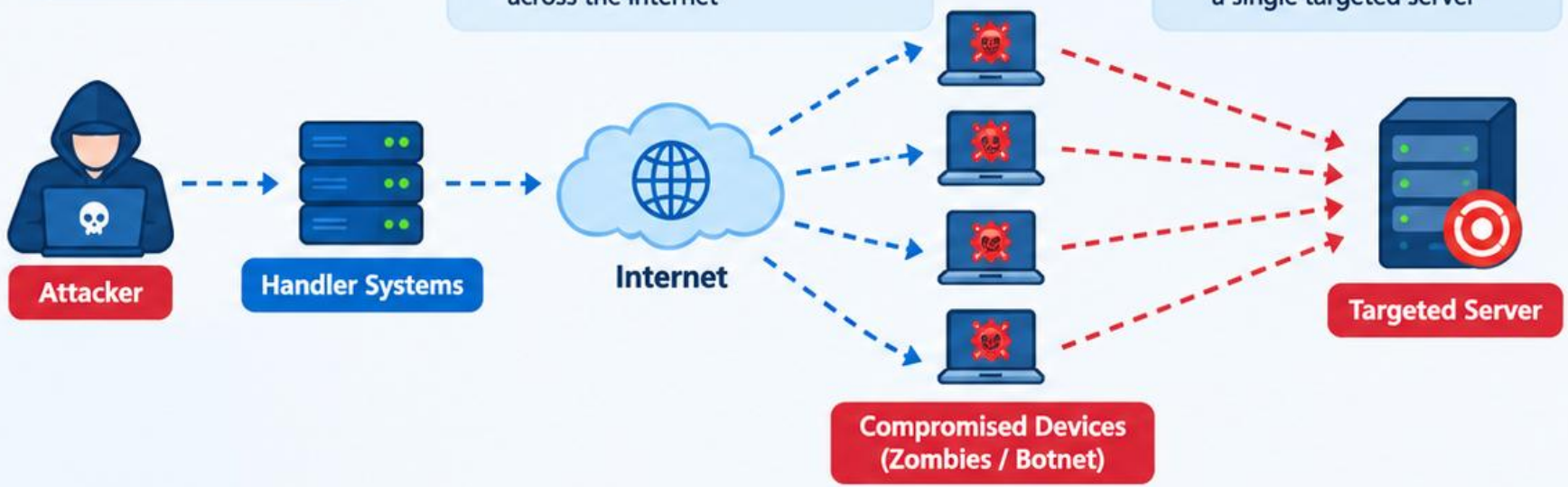
A distributed denial-of-service (DDoS) attack uses **many compromised devices (a botnet)** to overwhelm a **single target**, preventing legitimate users from accessing the service.

DDoS Impact

- **Loss of goodwill**
- **Network disruption**
- **Financial loss**
- **Service unavailability**

How Does a DDoS Attack Work?

1. Attacker controls **handler systems**
2. Handler systems coordinate compromised PCs (zombies/botnet) across the internet
3. Compromised devices send a large volume of traffic toward a single targeted server



This diagram shows the general concept of a DDoS attack for educational purposes only.

Basic Categories of DoS/DDoS Attack Vectors

Volumetric Attacks

- Consumes the bandwidth of target network or service
- The magnitude of attack is measured in **bits-per-second (bps)**
- Types of bandwidth depletion attacks:
  - Flood attacks
  - Amplification attacks

Attack Techniques

- UDP flood attack
- ICMP flood attack
- Ping of Death attack
- Smurf attack

Protocol Attacks

- Consumes other types of resources like **connection state tables** present in the network infrastructure components such as **load-balancers**, **firewalls**, and **application servers**
- The magnitude of attack is measured in **packets-per-second (pps)**

Attack Techniques

- SYN flood attack
- Fragmentation attack
- ACK flood attack
- TCP state exhaustion attack

Application Layer Attacks

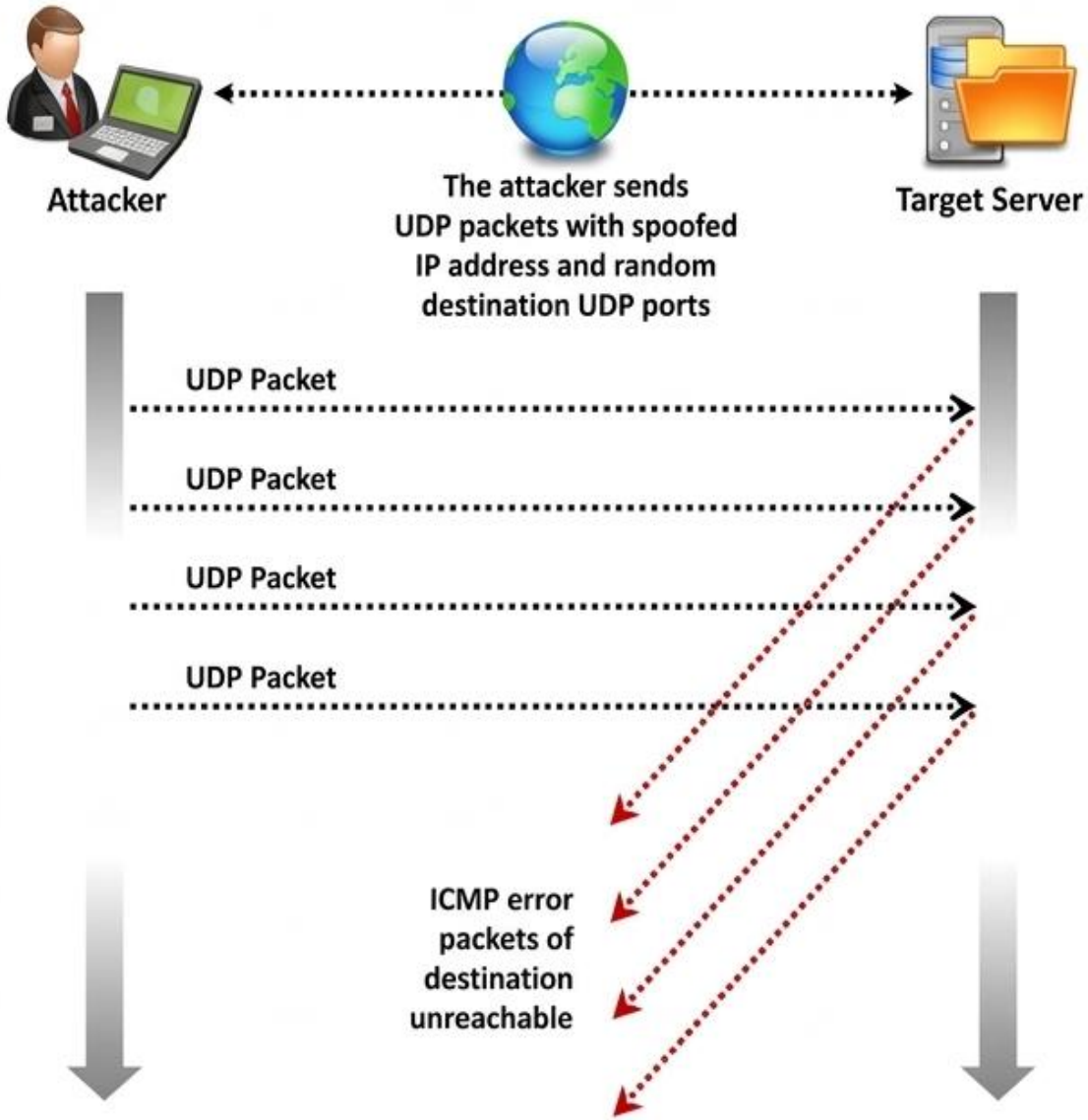
- Consumes the **application resources** or service thereby making it unavailable to other legitimate users
- The magnitude of attack is measured in **requests-per-second (rps)**

Attack Techniques

- HTTP GET/POST attack
- Slowloris attack

UDP Flood Attack

- An attacker sends **spoofed UDP packets** at a very high packet rate to a remote host on random ports of a target server using a large source IP range
- Flooding of UDP packets causes server to repeatedly check for **non-existent applications** at the ports
- Legitimate applications are inaccessible by the system and gives a **error reply** with an ICMP 'Destination Unreachable' packet
- This attack consumes **network resources** and available bandwidth, exhausting the network until it goes offline



Denial-of-Service |
DoS/DDoS Attack Techniques

ICMP Flood Attack

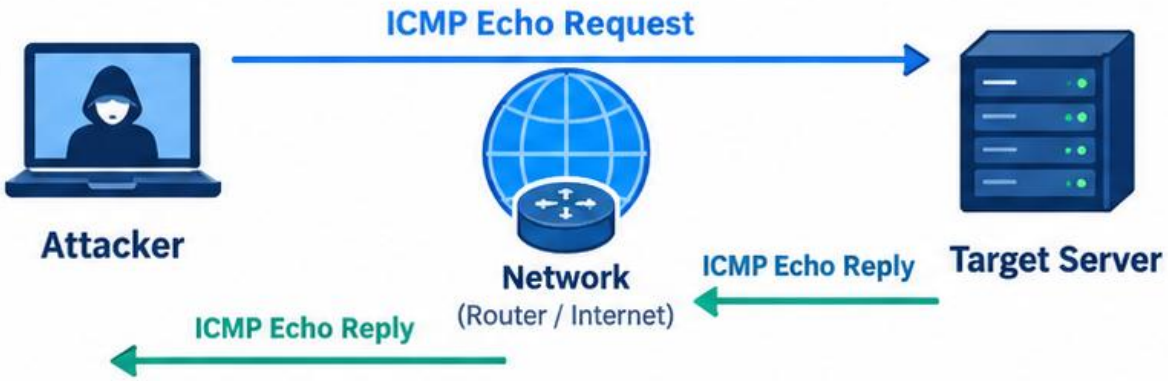
Cybersecurity Education
Learn | Protect | Build

Network administrators use ICMP for IP operations, troubleshooting, and error messages for **undeliverable packets.**

An ICMP flood attack sends large volumes of **ICMP Echo Request packets** to a victim system, directly or through reflection networks.

The victim responds to requests, and excessive traffic can consume bandwidth and resources, causing legitimate TCP/IP requests to **go unanswered.**

Defense: configure appropriate rate limits and filtering rules, monitor traffic thresholds, and use upstream DDoS protection when needed.

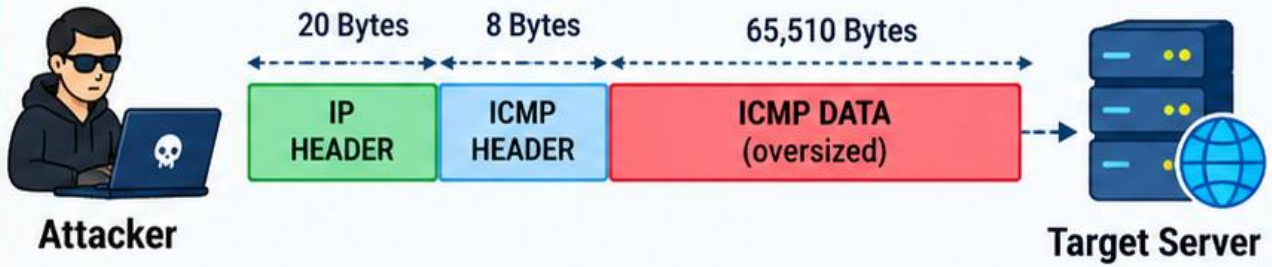




Ping of Death and Smurf Attack

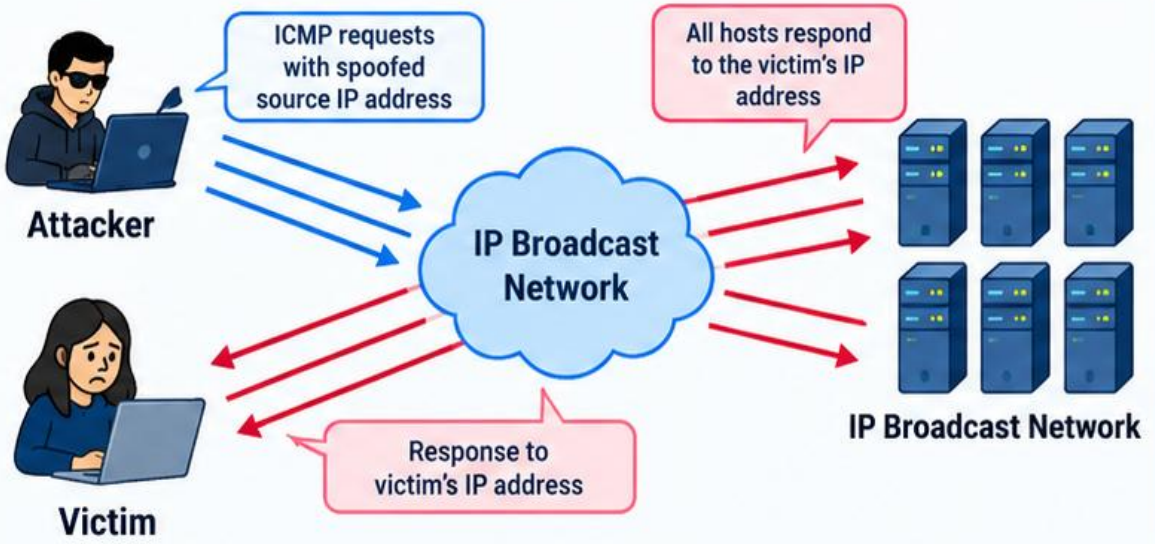
Ping of Death Attack

- In a Ping of Death (PoD) attack, an attacker tries to crash, **destabilize**, or **freeze** the targeted system or service by **sending malformed or oversized packets** using a simple ping command.
- For instance, the attacker sends a packet which has a size of **65,538 bytes** to the target web server. This size of the packet **exceeds the size limit prescribed by RFC 791IP** which is **65,535 bytes**. The reassembly process by the receiving system might cause the system to crash



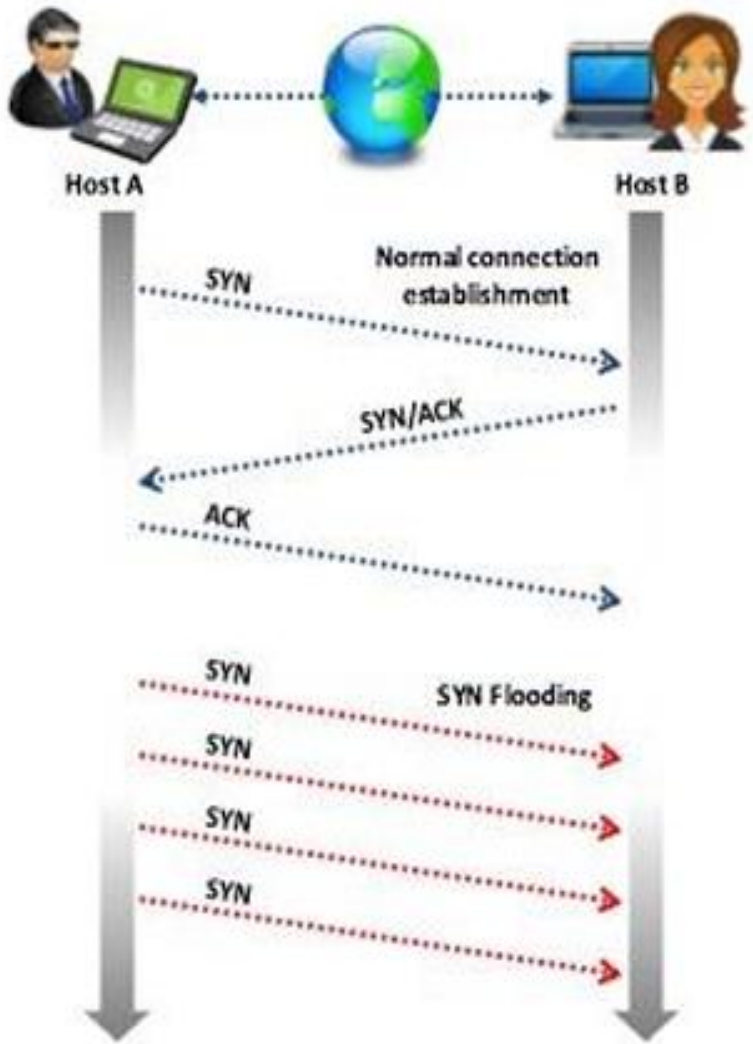
Smurf Attack

- In a Smurf attack, the attacker spoofs the **source IP address** with the victim's IP address and sends **large number of ICMP ECHO request packets** to an IP broadcast network.
- This causes all the hosts on the broadcast network to respond to the received **ICMP ECHO** requests. These responses will be sent to the victim machine, ultimately leading the machine to crash.



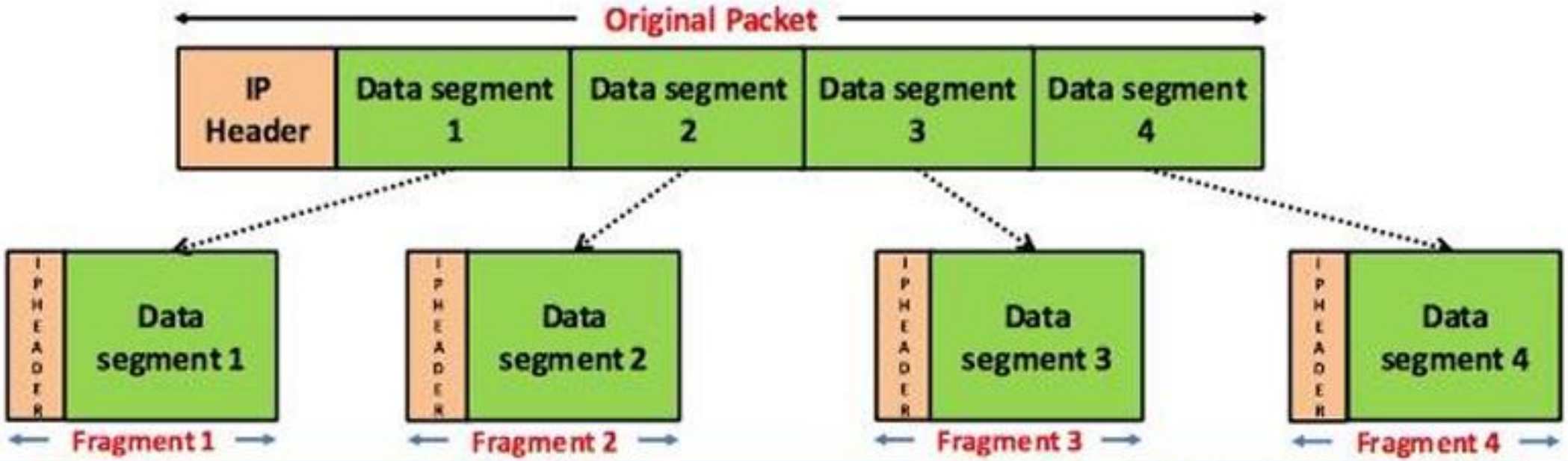
SYN Flood Attack

- The attacker sends a large number of **SYN request** to target server (victim) with **fake source IP addresses**
- The target machine sends back a **SYN ACK** in **response to the request** and waits for the ACK to complete the session setup
- The target machine **does not get the response** because the **source address is fake**
- SYN Flooding takes advantage of a flaw in the way most hosts implement the **TCP three-way handshake**
- When **Host B** receives the **SYN** request from Host A, it must keep track of the partially-opened connection in a "**listen queue**" for **at least 75 seconds**
- A malicious host can exploit the small size of the listen queue by **sending multiple SYN requests** to a host, but **never replying to the SYN/ACK**
- The victim's listen queue is quickly filled up
- This ability of **holding up** each incomplete **connection for 75 seconds** can be cumulatively used as a **Denial-of-Service attack**



Fragmentation Attack

- These attacks destroy a victim's ability to re-assemble the fragmented packets by flooding it with TCP or UDP fragments, resulting in reduced performance. Attacker sends large number of fragmented (1500+ byte) packets to a target web server with relatively small packet rate
- Since the protocol allows the fragmentation, these packets usually pass through the network equipments like routers, firewalls, IDS/IPS, etc. uninspected
- Reassembling and inspecting these large fragmented packets consumes excessive resources. Moreover the content in the packet fragments will be randomized by the attacker, which makes the process to consume more resource and leading the system to crash



HTTP GET/POST and Slowloris Attacks

HTTP GET/POST Attack

- HTTP Clients such as web browsers, etc. connect to a web server through HTTP protocol to send HTTP requests. These requests can be either HTTP GET or HTTP POST
- In HTTP GET attack, the attackers use time delayed HTTP header to hold on to HTTP connections and exhaust web server resources
- In HTTP POST attack, the attacker sends the HTTP requests with complete headers but incomplete message body to the target web server or application making the server wait for the rest of the message body

HTTP GET Attack



HTTP POST Attack



Slowloris Attack

- In the Slowloris attack, the attacker sends partial HTTP requests to the target web server or application
- Upon receiving the partial HTTP requests, the target server opens multiple open connections and keeps waiting for the requests to complete
- These requests will not be complete and as a result, the target server's maximum concurrent connection pool will be filled up and additional connection attempts will be denied

Normal HTTP request-response connection



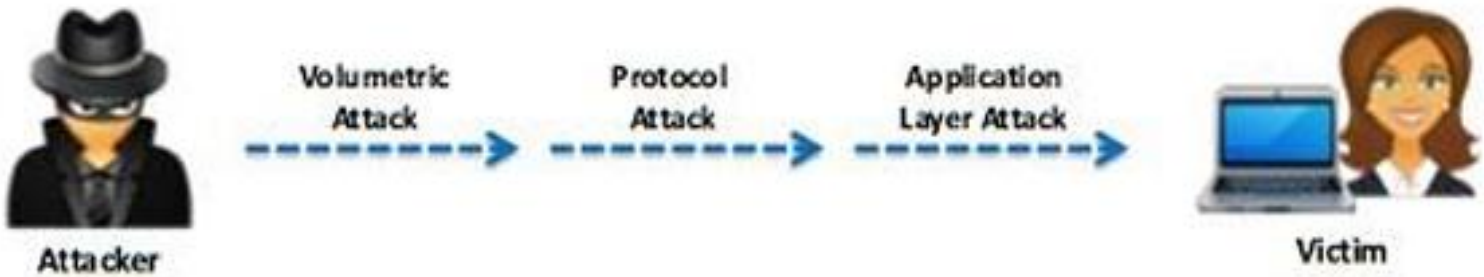
Slowloris DDoS attack



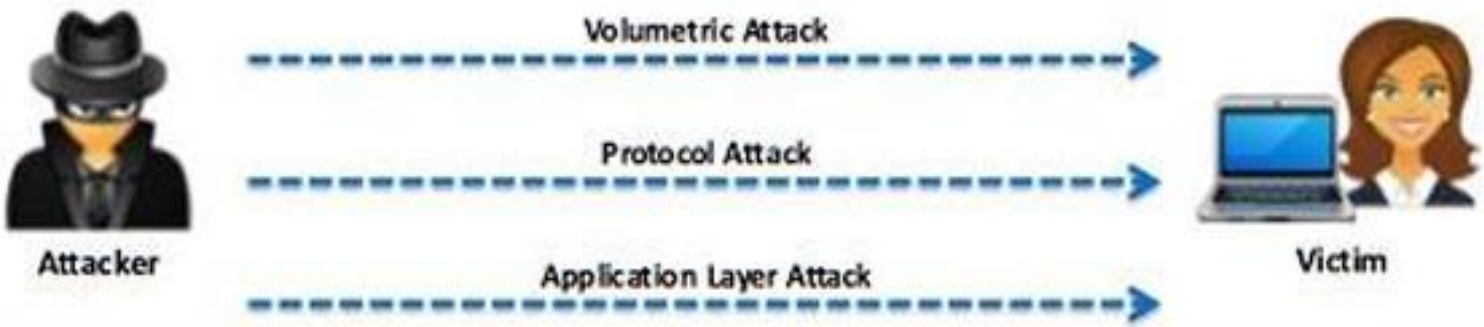
Multi-Vector Attack

- In multi-vector DDoS attacks, the attackers use combinations of volumetric, protocol, and application-layer attacks to take down the target system or service
- Attacker quickly changes from one form of DDoS attack (e.g.: SYN packets) to another (Layer 7), and so on
- These attacks are either launched one vector at a time or in parallel, in order to confuse a company's IT department and to make them spend all their resources and divert their focus to the wrong side

Multi-Vector attack in sequence



Multi-Vector attack in parallel



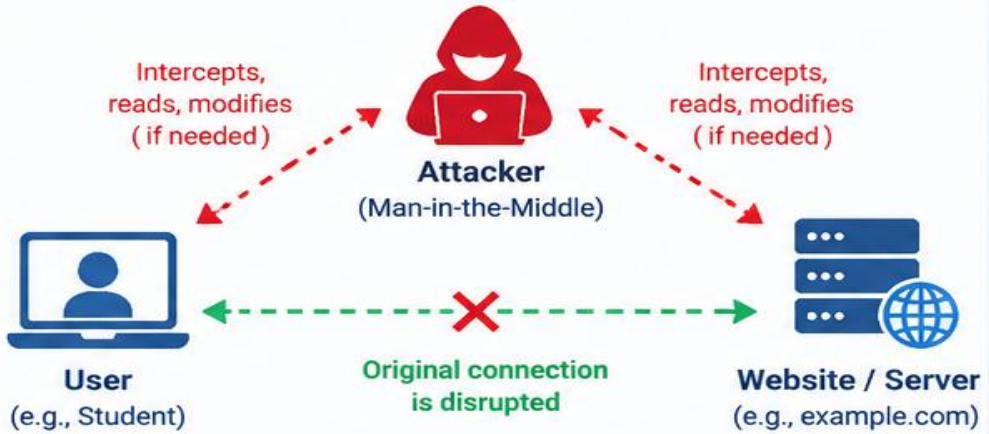
Man-in-the-Middle (MITM) Attack

An attacker secretly places themselves between two communicating parties and may monitor or modify their communication.

Key Points

- **Intercepts** communication between two parties.
- Can eavesdrop, modify, or inject data.
- Often occurs on insecure networks (e.g., public Wi-Fi).
- Can target web traffic, emails, or other network protocols.

How It Works (Diagram)

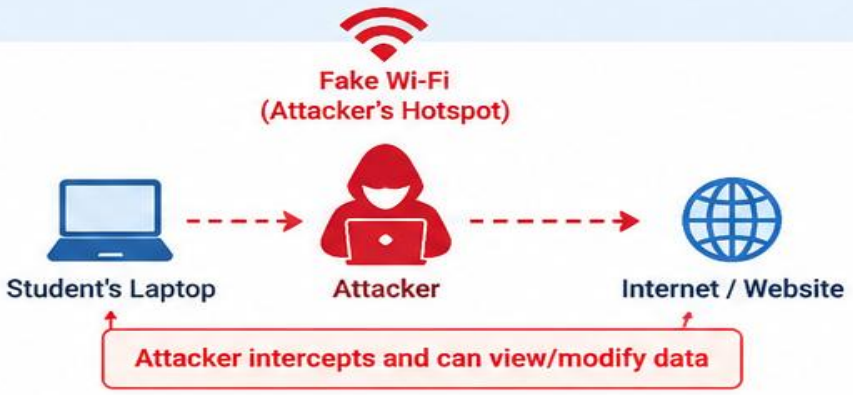


How It Is Performed (Steps)

1. **Set up a fake access point or spoof an existing network**
   The attacker creates a rogue Wi-Fi hotspot or uses ARP/DNS spoofing to position themselves between the user and the server.
2. **Redirect traffic**
   The attacker tricks the devices into sending their traffic through the attacker's device (e.g., using ARP spoofing or DNS spoofing).
3. **Intercept and analyze**
   The attacker captures the data (e.g., HTTP requests, login credentials, cookies, etc.).
4. **Modify or inject (optional)**
   The attacker can change the data or inject malicious content before forwarding it to the real destination.

Simple Example

A student connects to a public Wi-Fi network at a café. The attacker sets up a fake hotspot with a similar name (e.g., "FreeWiFi"). The student's laptop connects to the attacker instead of the real internet. The attacker can now see the student's browsing activity, login credentials, or modify web pages.



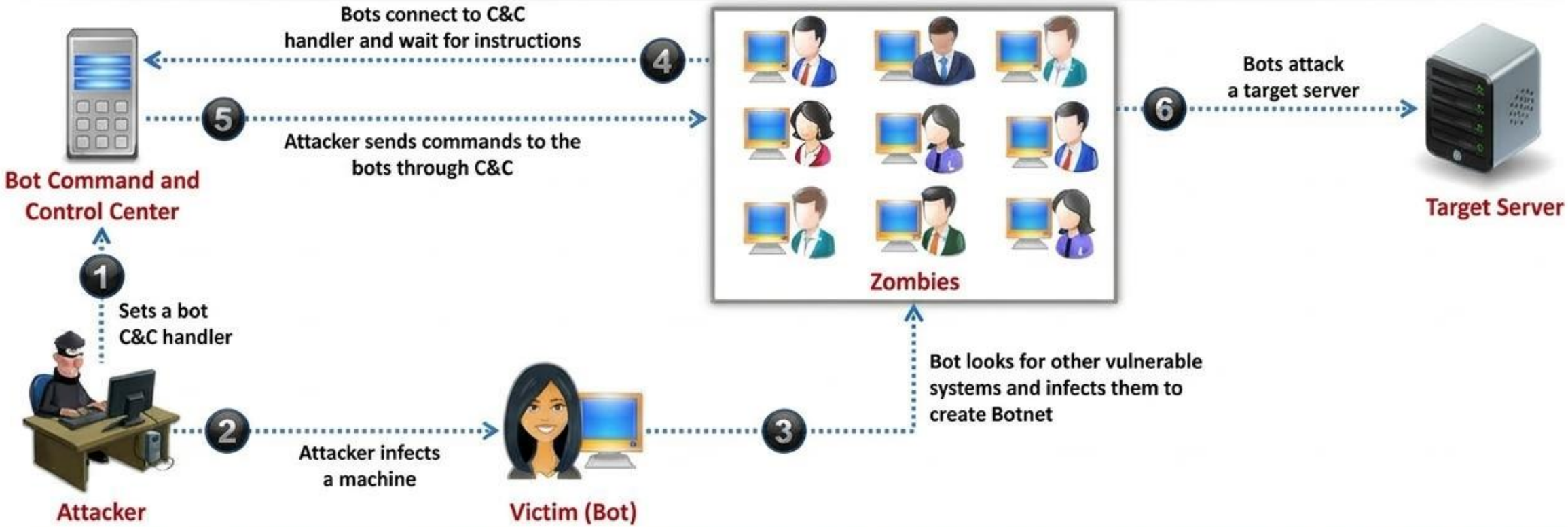
How to Prevent It

- Use HTTPS (encrypted connections).
- Avoid public Wi-Fi for sensitive activities.
- Use a VPN.
- Verify website certificates.
- Use secure protocols (e.g., WPA2/WPA3 for Wi-Fi).

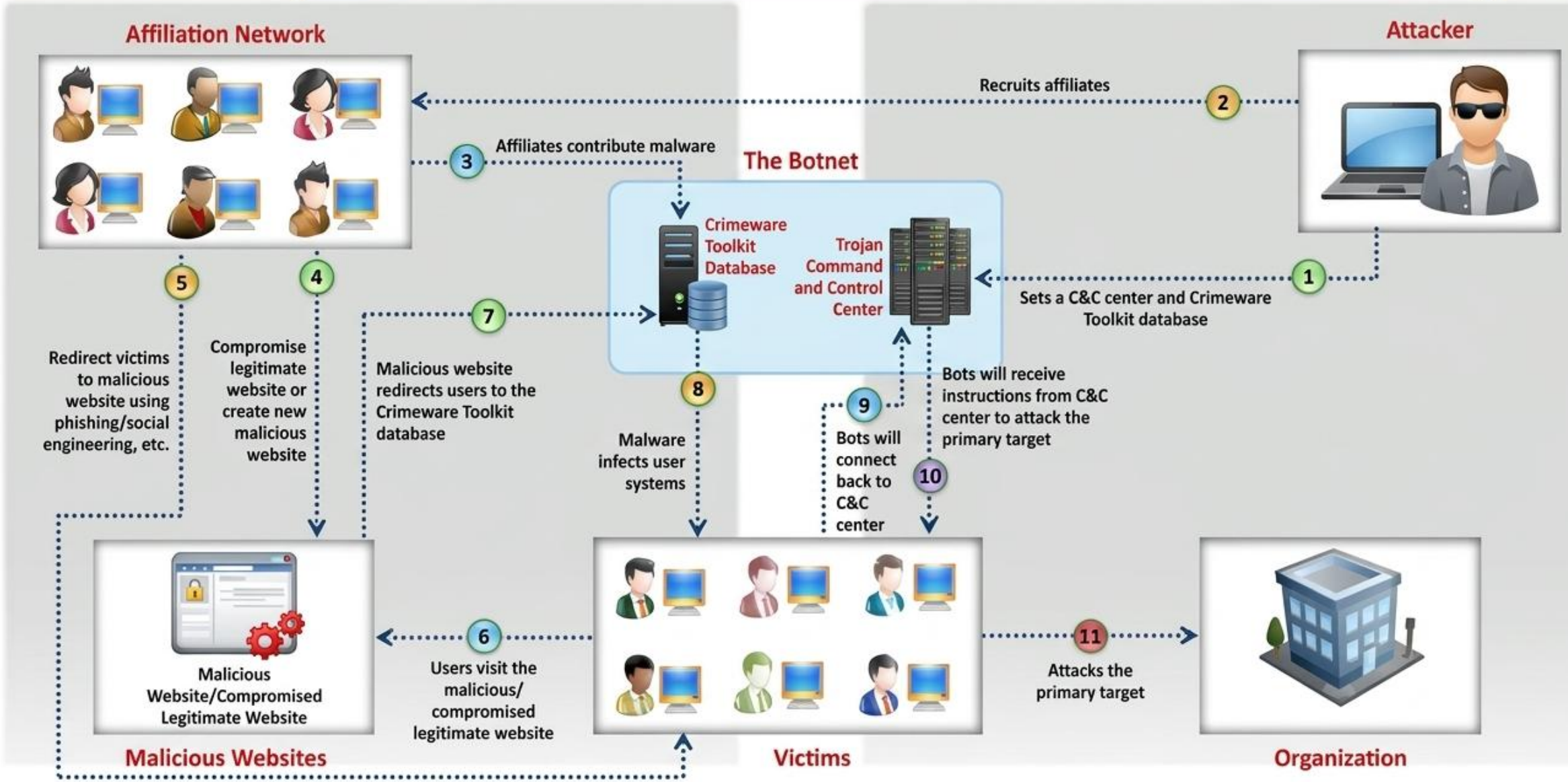
Botnet

- Bots are software applications that **run automated tasks over the Internet** and perform simple repetitive tasks, such as web spidering and search engine indexing
- A botnet is a huge network of compromised systems and can be used by an attacker to **launch denial-of-service attacks**

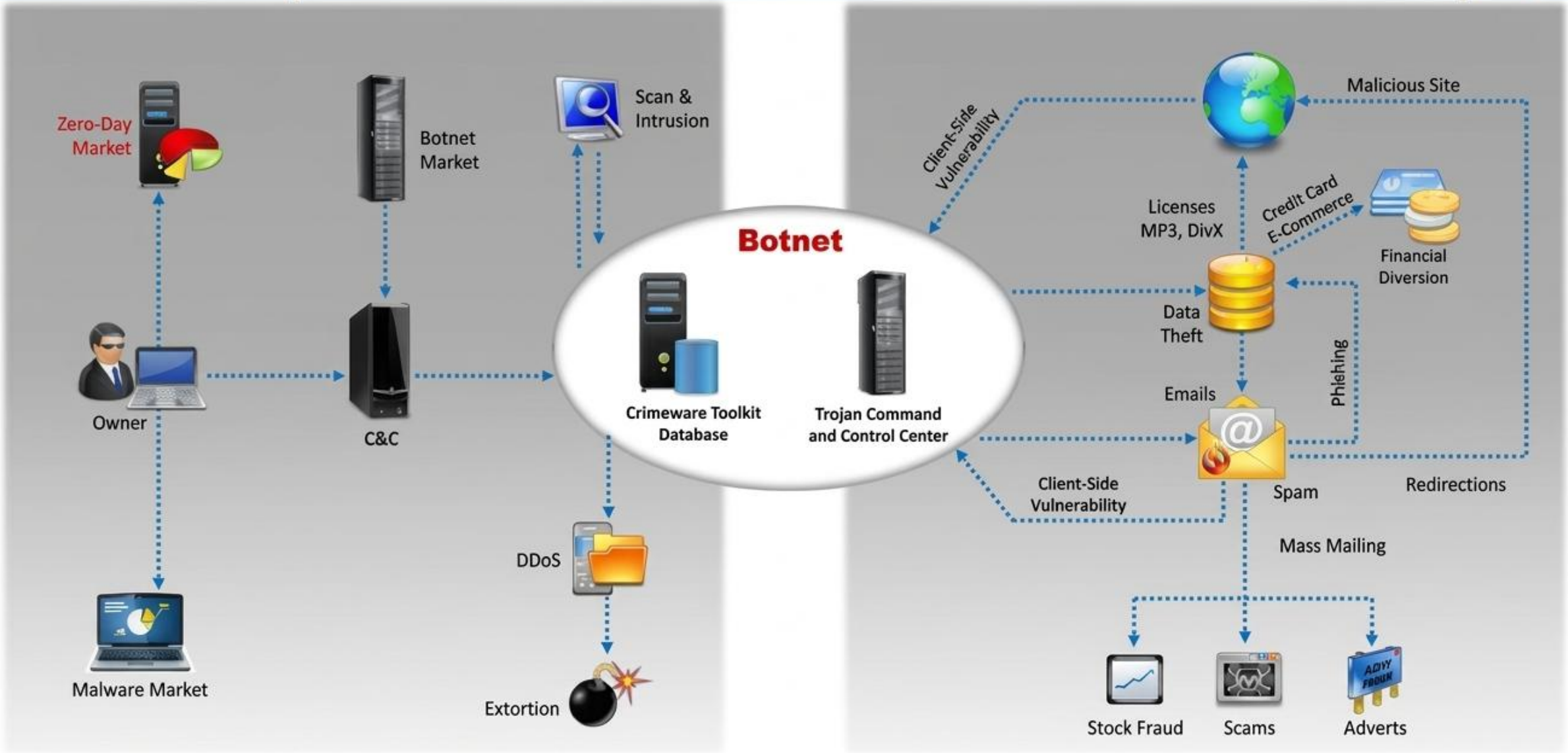




A Typical Botnet Setup



Botnet Ecosystem



What is a Botnet?

A botnet is a large network of infected devices ("bots" or "zombies") secretly controlled by an attacker.

How it forms: malware quietly infects thousands of PCs, phones, and smart devices. Their owners usually have no idea.

Attacker

Sends one command to the whole army

Bots / zombies

Thousands of infected devices obey at once

Target

Gets flooded from every direction (DDoS)

WHY THEY MATTER

Impact of Service Attacks

Downtime

Websites and apps become unreachable for users.

Lost revenue

An online shop earns nothing while it is offline.

Reputation damage

Customers lose trust in an unreliable service.

Distraction

A DDoS can hide a second, quieter attack.

Recovery cost

Staff time and services needed to restore operations.

Ransom (RDoS)

Attackers may demand payment to stop the flood.

DEFENSE

Defending Against DoS / DDoS

Firewalls & filtering

Block obviously bad or malformed traffic.

Rate limiting

Cap how many requests one source can send.

CDN / anti-DDoS

Services like Cloudflare absorb huge floods.

Load balancing

Spread traffic across many servers.

Traffic monitoring

Spot unusual spikes early and react fast.

Incident plan

Know exactly what to do when an attack starts.

PART 3

Footprinting & Reconnaissance

The information-gathering that happens BEFORE most attacks.

What is Footprinting & Reconnaissance?

Reconnaissance (recon) is gathering information about a target before attacking. Footprinting is building a detailed profile of that target.

Analogy: like a burglar watching a house for days — learning who lives there, when they leave, and which window is weak — before ever breaking in.

Why it matters: it is usually the FIRST phase of an attack. The more attackers learn, the easier the attack becomes. Defenders study it to reduce what they expose.

It's often the first step of "ethical hacking" too

Security testers do the same recon (with permission) to find what an attacker could see — then help the organization hide or fix it.

TWO APPROACHES

Passive vs Active Reconnaissance

PASSIVE

Gather info WITHOUT touching the target

- Uses public sources only
- Very hard to detect
- E.g. Google, social media, WHOIS records

ACTIVE

Interact DIRECTLY with the target

- Probes the systems directly
- More useful, but can be detected/logged
- E.g. port scanning, pinging servers

What Information Do They Look For?

Domain & IP info

Website addresses, IP ranges, name servers.

Employee details

Names, emails, job roles (great for phishing).

Technologies used

Web server, CMS, and software versions.

Open ports/services

Which doors are open on the network.

Email addresses

Formats like name@company.com to target.

Leaked data

Old breaches, passwords, exposed documents.

Common Recon Techniques

WHOIS lookup

Find who registered a domain and their contact info.

Example: Looking up when and by whom a website was registered.

DNS enumeration

Map a domain's servers and subdomains.

Example: Discovering mail.company.com and vpn.company.com.

Google dorking

Advanced search queries to find exposed info.

Example: site:company.com filetype:pdf to find leaked documents.

OSINT

Open-Source Intelligence from public/social media.

Example: Building a staff list from LinkedIn profiles.

GOING DEEPER

Scanning & Enumeration

After passive recon, attackers may SCAN the target to find live hosts, open ports, and services — then ENUMERATE details of each.

Host discovery

Find which devices are alive on a network.

Example: Pinging a range of IPs to see which respond.

Port scanning

Find which network ports are open.

Example: Discovering port 80 (web) and 22 (SSH) are open.

Service/version detect

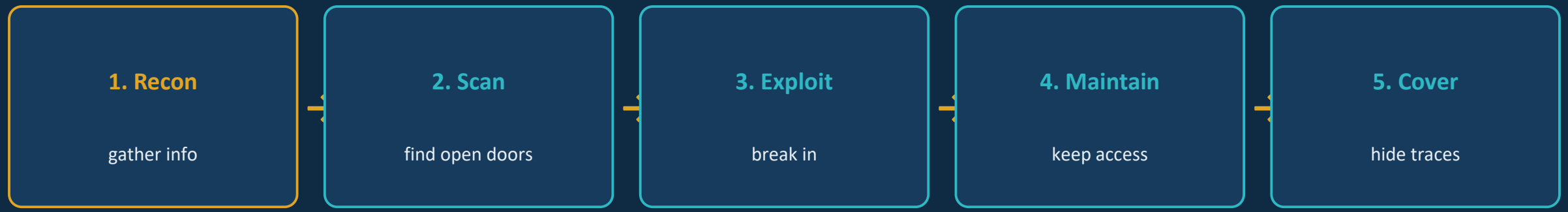
Identify the exact software and version running.

Example: Finding "Apache 2.4.49" — then checking it for CVEs.

THE BIGGER PICTURE

Where Recon Fits in an Attack

Recon is step one. This simplified chain shows how an attack usually flows:



Defender's takeaway

Stop attackers early: the less information you expose in the recon phase, the harder every later step becomes.

DEFENSE

How to Reduce Your Digital Footprint

Limit public info

Share less about staff, systems and tech online.

Lock down social media

Attackers mine LinkedIn and Facebook for details.

Hide server banners

Don't reveal software names and versions.

Use privacy on WHOIS

Keep domain registration details private.

Close unused ports

Fewer open doors means fewer targets.

Train staff

Teach people not to over-share work details.

Reconnaissance & Scanning Tools

Industry-standard tools students will meet. (Use only on systems you own or are authorized to test.)

Nmap

The classic scanner for hosts, open ports and services.

Wireshark

Captures and inspects live network traffic.

whois / dig / nslookup

Built-in commands for domain and DNS lookups.

theHarvester

Collects emails, names and subdomains (OSINT).

Shodan

A search engine for internet-connected devices.

Maltego / Recon-ng

Map relationships between people, domains and data.

TOOLS · PRACTICE

Safe Places to Practise

Practise ONLY in these legal environments or on systems you own. Never scan or attack others.

TryHackMe

Guided rooms on recon, scanning and DoS concepts.

Hack The Box

Practice machines to apply scanning & enumeration.

Metasploitable / VulnHub

Vulnerable VMs to scan and enumerate safely at home.

Kali / Parrot OS

Free security OSes with recon tools pre-installed.

Cloudflare (free tier)

See real anti-DDoS and rate-limiting in action.

Your own lab (VirtualBox)

Build an isolated network of VMs to experiment.

IMPORTANT

Recon & Attacks: Legal Boundaries

Port-scanning, DoS testing, or probing systems you don't own — without written permission — is ILLEGAL in most countries, even as a "test."

Always get permission

Written authorization before any active testing.

Passive ≠ free-for-all

Even OSINT must respect privacy and the law.

Use labs to learn

TryHackMe, HTB, and your own VMs are built for this.

Think about intent

The same tool can defend or attack — choose to defend.

PRACTICE ACTIVITY 1

Passive Recon on a Domain You Own

Safe, legal, and doable from any computer — use a domain you own or a public example.

Step 1	Run a WHOIS lookup (whois example.com) — who registered it, and when?
Step 2	Use nslookup or dig to find the site's IP and mail servers.
Step 3	Try a Google dork: site:example.com filetype:pdf.
Step 4	Note what info is publicly visible about the domain.
Step 5	Ask: what could a defender hide to reduce this footprint?

PRACTICE ACTIVITY 2

Scan a Lab Machine with Nmap

Do this ONLY inside a legal lab (e.g. Metasploitable in VirtualBox, or a TryHackMe room).

Step 1	Set up a vulnerable VM (Metasploitable) on an isolated network.
Step 2	From Kali, run nmap -sn to discover live hosts.
Step 3	Run nmap -sV <target-IP> to list open ports and versions.
Step 4	Pick one service version and search it on the NVD for CVEs.
Step 5	Write down how the owner could close or patch each open door.

QUICK REFERENCE

Key Terms at a Glance

DoS

Flooding one system to make it unavailable.

DDoS

A DoS from many devices at once.

Botnet

A network of infected "zombie" devices.

Footprinting

Building a detailed profile of a target.

Reconnaissance

Gathering info before an attack.

Passive recon

Info-gathering without touching the target.

Active recon

Directly probing the target (e.g. scanning).

OSINT

Intelligence from public / open sources.

RECAP

Week 4 Summary

- Common cyber threats include phishing, ransomware, password attacks, MITM, SQL injection and insider threats.
- A DoS attack floods a system so real users can't reach it; a DDoS does this from thousands of devices (a botnet).
- DoS/DDoS harms availability — causing downtime, lost revenue and reputation damage; defenses include CDNs, rate limiting and monitoring.
- Reconnaissance is gathering info before an attack; footprinting builds a full profile of the target.
- Recon is passive (public sources, hard to detect) or active (directly probing, e.g. port scanning).
- Tools: Nmap, Wireshark, WHOIS/dig, theHarvester, Shodan — practise only in legal labs with permission.

CHECK YOUR UNDERSTANDING

Review Questions

1. Name four common cyber threats and give a short example of each.
2. What is a DoS attack? How is a DDoS attack different?
3. What is a botnet, and what role does it play in a DDoS?
4. List three ways to defend against service attacks.
5. Explain the difference between passive and active reconnaissance.
6. What information do attackers gather during footprinting, and how can defenders reduce it?

WEEK 5 PREVIEW

Coming Next: Malware Threats in Depth

- Malware and types of malware
- Impact of malware on systems
- Stages of a malware attack and payloads